Security Risk Assessment Report

Christiana Sebree

2026

Company Overview

Company Name: ZenFlow Yoga Studio

Industry: Health & Wellness

Business Size: Small Business

Employees: 15

Active Members: Approximately 400

Business Type: Fictional Organization (Simulated Cybersecurity Assessment)

ZenFlow Yoga Studio is a fictional health and wellness business that provides yoga classes, private instruction, and membership-based services. The company employs 15 staff members and serves approximately 400 active members.

ZenFlow relies on digital technology to manage daily operations, including class scheduling, membership management, payment processing, employee communications, and customer records. The organization utilizes cloud-based software, shared Google Drive documents, company computers, and wireless networks to support its operations.

The studio collects and maintains sensitive information, including customer contact details, membership records, employee information, and account credentials. Payment transactions are processed through a third-party payment platform.

As a small business with limited IT resources, ZenFlow faces potential cybersecurity risks involving unauthorized access, phishing attacks, weak password management, data breaches, and inadequate network security.

This simulated security risk assessment will evaluate potential vulnerabilities within the organization's digital environment, identify critical assets, and recommend security controls to reduce risk and strengthen its overall cybersecurity posture.

Scope of Assessment

Assessment Objective

The objective of this simulated cybersecurity risk assessment is to identify potential security vulnerabilities within ZenFlow Yoga Studio's digital infrastructure, evaluate associated risks, and recommend appropriate security controls to protect sensitive business and customer information.

Systems and Assets Within Scope

The assessment will focus on the following areas:

1. Access Control and Authentication

- Employee login credentials and password management
- User permissions and access to sensitive information
- Multi-factor authentication (MFA) practices

2. Data Protection and Privacy

- Customer personal information and membership records
- Employee information and payroll records
- Storage and sharing of sensitive business documents

3. Network Security

- Employee and guest Wi-Fi networks
- Wireless network access controls
- Security of company computers and connected devices

4. Cloud-Based Applications

- Online class scheduling and membership management systems
- Google Drive file-sharing permissions
- Third-party payment processing platforms

5. Employee Security Awareness

- Recognition of phishing emails and social engineering attempts
- Employee cybersecurity training
- Procedures for reporting suspicious activity

Assessment Limitations

This assessment is based on a fictional business environment and simulated security scenarios. No real company systems, customer information, or networks will be accessed or tested.

The assessment will focus on identifying hypothetical vulnerabilities, evaluating potential risks, and developing security recommendations based on cybersecurity best practices.

Asset Identification

Purpose

The purpose of asset identification is to determine which information, systems, and technological resources are essential to ZenFlow Yoga Studio's daily operations. Identifying these assets helps prioritize security measures, assess potential threats, and reduce the risk of unauthorized access, data loss, and operational disruptions.

Critical Business Assets

Asset	Description	Importance
Customer Information	Member names, email addresses, phone numbers, and membership details	High
Employee Credentials	Usernames, passwords, and employee account access	High
Payment Processing System	Third-party platform used to process membership payments	High
Employee Records	Payroll information, contact details, and employment documents	High
Google Drive	Cloud storage for business documents and internal communications	Medium
Scheduling Software	Platform used for class bookings, instructor schedules, and attendance	High
Company Computers	Devices used for administrative and business operations	Medium
Wi-Fi Networks	Wireless internet access for employees and studio members	Medium

Asset Classification

For this assessment, assets are classified according to their importance to business operations and the potential consequences of unauthorized access, loss, or disruption.

High Importance: Assets containing sensitive information or supporting essential business operations. A security incident involving these assets could result in financial loss, privacy violations, or significant operational disruption.

Medium Importance: Assets supporting daily business activities where a security incident could cause temporary disruptions, reduced productivity, or increased security exposure.

Low Importance: Assets with limited sensitivity or operational impact, where compromise would have minimal consequences for the organization.

Assessment Summary

Based on the simulated business environment, customer information, employee credentials, payment processing systems, and employee records are considered particularly important assets requiring strong security controls.

These assets will be prioritized during the next stage of the assessment to identify potential threats, vulnerabilities, and opportunities for security improvement.

Security Vulnerabilities

Purpose

The purpose of this section is to identify potential cybersecurity vulnerabilities within ZenFlow Yoga Studio's digital environment. These vulnerabilities represent weaknesses that could be exploited by malicious actors, potentially compromising sensitive information, disrupting business operations, or causing financial losses.

The following findings are based on simulated security conditions established for this assessment.

Identified Security Vulnerabilities

Vulnerability 1: Weak Password Management

Employees frequently reuse passwords across multiple business accounts, and the organization does not enforce strong password requirements.

- **Affected Assets:** Employee credentials, scheduling software, Google Drive
- **Potential Threat:** Credential theft and unauthorized account access
- **Potential Impact:** Exposure of confidential business and customer information

Vulnerability 2: Lack of Multi-Factor Authentication (MFA)

Employee accounts rely solely on passwords for authentication without requiring additional identity verification.

- **Affected Assets:** Employee accounts, cloud applications, business records
- **Potential Threat:** Account compromise following password theft
- **Potential Impact:** Unauthorized access to sensitive information and business systems

Vulnerability 3: Inadequate Employee Cybersecurity Training

Employees do not receive regular cybersecurity awareness training on phishing, social engineering, or suspicious online activity.

- **Affected Assets:** Employee accounts, customer records, business systems
- **Potential Threat:** Phishing attacks, malicious links, and credential harvesting
- **Potential Impact:** Data breaches, malware infections, and financial loss

Vulnerability 4: Unrestricted Google Drive Access

Shared business folders are accessible to employees who do not require access to all stored information for their job responsibilities.

- **Affected Assets:** Google

Risk Analysis and Evaluation

Purpose

The purpose of this risk analysis is to evaluate the likelihood and potential impact of the cybersecurity vulnerabilities identified within ZenFlow Yoga Studio's simulated digital environment.

Each vulnerability is assigned a likelihood score and an impact score using a five-point rating system. These scores are used to calculate an overall risk rating and prioritize security improvements.

Risk Assessment Methodology

Risk levels are calculated using the following formula:

Risk Score = Likelihood × Impact

Likelihood Scale

- 1 – Rare: Highly unlikely to occur
- 2 – Unlikely: Low probability of occurrence
- 3 – Possible: Could occur under certain circumstances
- 4 – Likely: Expected to occur under existing conditions
- 5 – Almost Certain: Very high probability of occurrence

Impact Scale

- 1 – Insignificant: Minimal operational impact
- 2 – Minor: Limited disruption or financial loss
- 3 – Moderate: Noticeable operational or financial consequences
- 4 – Major: Significant financial loss or business disruption
- 5 – Severe: Critical data exposure or substantial operational damage

Risk Classification

Risk Score	Risk Level
1–4	Low

5–9	Medium
10–16	High
17–25	Critical

Security Risk Assessment Results

Identified Vulnerability	Likelihood	Impact	Risk Score	Risk Level
Weak Password Management	4	5	20	Critical
Lack of Multi-Factor Authentication	4	5	20	Critical
Inadequate Security Training	4	4	16	High
Unrestricted Google Drive Access	3	4	12	High
Insufficient Network Segmentation	3	4	12	High
Inadequate Software Updates	4	4	16	High

Risk Analysis Findings

The simulated assessment identified two critical risks and four high-level risks.

Critical Risks

Weak password management and the absence of multi-factor authentication received the highest risk scores of 20. These vulnerabilities could increase the likelihood of unauthorized access to employee accounts and sensitive business information.

High Risks

Inadequate cybersecurity training, unrestricted Google Drive access, insufficient network segmentation, and inconsistent software updates received risk scores ranging from 12 to 16.

These weaknesses could expose the organization to phishing attacks, unauthorized information disclosure, network compromise, and exploitation of outdated software.

Risk Prioritization

Based on the calculated risk scores, ZenFlow Yoga Studio should prioritize improvements to authentication security, followed by employee cybersecurity training, software patch management, access control restrictions, and network segmentation.

These findings provide a foundation for developing security recommendations that reduce potential threats and strengthen the organization's overall security posture.

Assessment Note: All risk ratings are illustrative estimates based on fictional conditions. They do not represent verified vulnerabilities or measured incident probabilities.

Security Recommendations and Mitigation Strategies

Purpose

The purpose of this section is to develop security recommendations that address the vulnerabilities identified during ZenFlow Yoga Studio's simulated cybersecurity risk assessment.

Each recommendation is designed to reduce the likelihood of security incidents, minimize potential business impact, and strengthen the organization's overall security posture.

Recommendations are prioritized according to the risk scores established in Section 5, considering the organization's size, operational needs, and available resources.

1. Weak Password Management

Risk Level: Critical (20/25)

Identified Vulnerability: Employees reuse passwords across multiple business accounts, increasing the risk of credential compromise and unauthorized access.

Recommended Security Controls:

- Implement a company-wide password management policy.
- Require unique, strong passwords for all employee accounts.
- Introduce a reputable password manager to securely generate and store credentials.
- Prohibit password sharing between employees.
- Require immediate password changes when credentials are suspected of being compromised.

Implementation Priority: Immediate (0–30 days)

Responsible Party: Studio Management / IT Administrator

Expected Outcome: Reduced risk of credential theft, unauthorized account access, and exposure of sensitive business information.

2. Lack of Multi-Factor Authentication (MFA)

Risk Level: Critical (20/25)

Identified Vulnerability: Employee accounts rely exclusively on passwords for authentication.

Recommended Security Controls:

- Enable MFA for all supported business applications.
- Prioritize MFA for email, Google Workspace, payroll, and administrative accounts.
- Use authenticator applications or phishing-resistant security keys where supported.
- Provide employees with instructions for configuring and using MFA.
- Periodically review authentication settings and account access.

Implementation Priority: Immediate (0–30 days)

Responsible Party: IT Administrator / Studio Management

Expected Outcome: Reduced likelihood of unauthorized account access resulting from compromised passwords.

3. Inadequate Employee Cybersecurity Training

Risk Level: High (16/25)

Identified Vulnerability: Employees do not receive consistent training on phishing, social engineering, and cybersecurity awareness.

Recommended Security Controls:

- Introduce mandatory cybersecurity awareness training for all employees.
- Educate staff on recognizing phishing emails, suspicious links, and fraudulent login requests.
- Conduct periodic simulated phishing exercises.

- Establish a clear procedure for reporting suspicious emails or security incidents.
- Provide cybersecurity training during new employee onboarding.

Implementation Priority: Short-Term (30–60 days)

Responsible Party: Studio Management / HR

Expected Outcome: Improved employee security awareness and reduced likelihood of successful social engineering attacks.

4. Unrestricted Google Drive Access

Risk Level: High (12/25)

Identified Vulnerability: Employees have access to shared business documents that may not be necessary for their job responsibilities.

Recommended Security Controls:

- Implement role-based access control (RBAC).
- Restrict access to sensitive files according to employee responsibilities.
- Apply the principle of least privilege.
- Review shared folder permissions regularly.
- Remove access promptly when employees leave the organization or change roles.
- Limit external file sharing where appropriate.

Implementation Priority: Short-Term (30–60 days)

Responsible Party: Studio Management / Google Workspace Administrator

Expected Outcome: Reduced risk of unauthorized data exposure and improved protection of confidential business information.

5. Insufficient Network Segmentation

Risk Level: High (12/25)

Identified Vulnerability: Employee and guest devices connect to the same wireless network without appropriate separation.

Recommended Security Controls:

- Establish separate wireless networks for employees and guests.
- Prevent guest devices from accessing internal business systems.
- Enable appropriate router firewall settings and client isolation.
- Use WPA2-AES or WPA3 encryption where supported.

- Restrict access to network administration settings.
- Periodically review network configurations and connected devices.

Implementation Priority: Short-Term (30–60 days)

Responsible Party: IT Administrator / Network Service Provider

Expected Outcome: Reduced risk of unauthorized network access, lateral movement, and compromise of internal business systems.

6. Inadequate Software Update Procedures

Risk Level: High (16/25)

Identified Vulnerability: Company computers and business applications do not follow a consistent software update schedule.

Recommended Security Controls:

- Enable automatic security updates where appropriate.
- Establish a formal patch management schedule.
- Prioritize critical security patches according to severity and exposure.
- Maintain an inventory of company devices and installed software.
- Remove unsupported or unnecessary applications.
- Periodically verify that updates have been successfully installed.

Implementation Priority: Short-Term (30–60 days), with urgent patches addressed sooner

Responsible Party: IT Administrator / Studio Management

Expected Outcome: Reduced exposure to known software vulnerabilities, malware infections, and preventable system compromises.

7. Implementation Priorities

Security Improvement	Risk Level	Target Timeline
Strengthen Password Management	Critical	0–30 Days
Implement Multi-Factor Authentication	Critical	0–30 Days

Improve Employee Security Training	High	30–60 Days
Establish Software Patch Management	High	30–60 Days
Restrict Google Drive Permissions	High	30–60 Days
Implement Network Segmentation	High	30–60 Days

8. Security Improvement Summary

The proposed mitigation strategies address ZenFlow Yoga Studio's most significant simulated cybersecurity risks through improvements in authentication, access management, employee awareness, network protection, and software maintenance.

Critical vulnerabilities involving password management and multi-factor authentication should receive immediate attention due to their potential impact on sensitive business information.

High-risk vulnerabilities should be addressed through a structured implementation plan that considers available resources and operational requirements.

Following implementation, the organization should reassess each vulnerability to evaluate the effectiveness of the security controls and determine whether residual risks remain acceptable.

Assessment Limitation: These recommendations are proposed controls for a fictional organization. No security changes have been implemented or independently verified as part of this project.

Conclusion and Final Assessment

Assessment Overview

This simulated cybersecurity risk assessment evaluated potential security vulnerabilities within ZenFlow Yoga Studio, a fictional small business operating in the health and wellness industry.

The assessment focused on critical business assets, including customer information, employee credentials, cloud-based applications, payment processing systems, and internal network infrastructure.

Using a structured risk assessment methodology, six simulated security vulnerabilities were identified and evaluated according to their likelihood of exploitation and potential business impact.

Summary of Findings

The assessment identified the following risk distribution:

- **Critical Risks:** 2
- **High Risks:** 4
- **Medium Risks:** 0
- **Low Risks:** 0

The most significant risks involved weak password management and the absence of multi-factor authentication, both receiving risk scores of 20 out of 25.

Additional high-priority concerns included inadequate employee cybersecurity training, unrestricted Google Drive permissions, insufficient network segmentation, and inconsistent software update procedures.

These simulated vulnerabilities demonstrate how weaknesses in authentication, employee awareness, and technology management could expose a small business to cybersecurity threats.

Overall Security Risk Evaluation

Based on the simulated findings, ZenFlow Yoga Studio's overall cybersecurity risk posture is assessed as **High Risk**, with two individual vulnerabilities classified as Critical.

This overall rating represents a qualitative judgment based on the identified scenarios rather than a separate calculated score.

Without appropriate mitigation strategies, these vulnerabilities could increase the likelihood of unauthorized account access, sensitive information exposure, financial losses, and operational disruptions.

Recommended Next Steps

To strengthen its cybersecurity posture, ZenFlow Yoga Studio should prioritize the following actions:

1. Implement stronger password management policies and multi-factor authentication.
2. Establish recurring cybersecurity awareness training for employees.
3. Restrict access to sensitive business documents using role-based permissions.
4. Separate employee and guest wireless networks.
5. Introduce consistent software updates and patch management procedures.
6. Conduct periodic security reviews and reassess identified risks following the implementation of security controls.

Final Assessment Statement

This assessment demonstrates the importance of proactive cybersecurity risk management within small businesses that rely on cloud-based applications, digital payment systems, and electronic customer records.

By identifying potential vulnerabilities, assigning risk scores, and developing prioritized mitigation strategies, organizations can make informed decisions about protecting critical assets and reducing security exposure.

The recommended security improvements provide a practical framework for strengthening ZenFlow Yoga Studio's simulated cybersecurity environment.

Assessment Limitations

This project was conducted as an independent cybersecurity portfolio exercise using a fictional organization and simulated security conditions.

No live systems were tested, no real vulnerabilities were verified, and no security controls were implemented.

Risk scores and recommendations were developed for educational purposes to demonstrate foundational cybersecurity risk assessment, analysis, and reporting skills.